Bezpieczeństwo systemów komputerowych

Wstęp do kursu

Bezpieczeństwo systemów komputerowych jest niezwykle ważnym i istotnym elementem, niezbędnym do prawidłowego funkcjonowania każdej organizacji. W dużych organizacjach, gdzie stworzone są sieci korporacyjne, wiele zabezpieczeń realizowanych jest z wykorzystaniem odpowiednich mechanizmów i technologii sieciowych. Nie wolno jednak zapominać o mniejszych przedsiębiorstwach, z mniejszymi sieciami, czy wręcz o komputerach, które działają niezależnie. Bezpieczeństwo takich maszyn również musi być zapewnione i musi stać na wysokim poziomie. W ramach tego kursu zostaną zaprezentowane zagadnienia, które odnoszą się do elementów bezpieczeństwa związanych z:

- cała organizacją,
- pojedynczymi komputerami,
- pewnymi elementami z pogranicza pojedynczej stacji roboczej i sieci.

Zaprezentowane zostaną również zagadnienia związane z zasadami tworzenia polityki bezpieczeństwa dla całej firmy. Omówione zostaną poszczególne jej poziomy:

- poziom organizacji — związany z procedurami,
- poziom związany z infrastrukturą sieciową oraz pojedynczymi stacjami i urządzeniami, jakie działają w ramach organizacji, a mogą mieć wpływ na bezpieczeństwo.

W ramach kursu zostaną przedstawione także zagadnienia:

- związane z bezpieczeństwem fizycznym komputerów,
- bezpiecznego dostępu (system haseł),
- związane z ochroną plików i aplikacji zainstalowanych na pojedynczych komputerach,
- dotyczące ochrony integralności systemu komputerowego oraz kontroli uruchamianych w systemie programów.

W ramach kursu będą również omówione zagadnienia związane z szyfrowaniem danych. Pokazane zostaną podstawowe metody szyfrowania oraz mechanizmy zarządzania certyfikatami (infrastruktura klucza publicznego — PKI). Znajdą się tutaj także elementy szyfrowania symetrycznego i asymetrycznego, które szerzej były omawiana w ramach kursu *Techniki kryptograficzne* oraz pojawią w ramach kursu *Bezpieczeństwo systemów sieciowych*.

Informacje zaprezentowane w tym kursie są wystarczające do tego, aby dla organizacji (firmy) o średniej wielkości zbudować politykę bezpieczeństwa, która będzie zawierała:

— elementy procedur i zasad, jakie będą w niej obowiązywały,
— ochronę fizyczną pojedynczych komputerów oraz zapewnienie integralności zapisów na lokalnych dyskach,
— bezpieczne korzystanie z aplikacji oraz posługiwanie się mechanizmami szyfrowania w zakresie ochrony danych oraz wymiany tych danych między użytkownikami.

Współczesne techniki kryptograficznej ochrony danych

Wstęp
1. Klucze kryptograficzne
2. Ochrona tajności danych — algorytmy szyfrowania
3. Szyfrowanie danych metodami asymetrycznymi
4. Metody ochrony wiarygodności danych
   4.1. Ochrona integralności danych
   4.2. Ochrona integralności przy użyciu współdzielonego sekretu
5. Ochrona wiarygodności danych metodami kryptografii asymetrycznej
   5.1. Ochrona wiarygodności danych w kryptosystemie RSA
   5.2. Jednoczesna ochrona wiarygodności i tajności wiadomości
   5.3. Podpisy cyfrowe
   5.4. Wyznaczanie podpisu cyfrowego metodą RSA
   5.5. Algorytm DSA wyznaczania podpisu cyfrowego
Bibliografia

Wstęp

Najważniejszym zasobem przechowywanym i przesyłanym w systemach komputerowych są dane tworzone przez użytkowników. Próby uzyskania nieuprawnionego dostępu do informacji, podejmowane w celu ich poznania, modyfikacji lub zniszczenia, stanowią główny powód ataków na systemy informatyczne. Jedynym skutecznym sposobem przeciwdziałania ujawnieniu treści poufnych danych lub zapobiegania ich modyfikacji jest wykorzystanie metod ochrony informacji, oferowanych przez współczesną kryptografię. Mimo złożoności metod kryptograficznych, błyskawiczny postęp technologii wytwarzania elementów infrastruktury informatycznej sprawił, że algorytmy kryptograficznej ochrony danych stały się powszechnie stosowanym elementem współczesnych programów komputerowych. Dlatego też rozumienie istoty realizowanych operacji ochrony danych jest niezbędnym elementem wiedzy każdego współczesnego informatyka, odpowiadającego za potencjalne konsekwencje wyboru niewłaściwych sposobów i metod zabezpieczenia przesyłanych i przechowywanych informacji.

W niniejszym module zostanie dokonany przegląd stosowanych obecnie technik kryptograficznej ochrony danych. Przedstawione informacje będą zgrupowane w sposób odzwierciedlający podstawowe cele formułowane dla zabezpieczania danych, obejmując:

- metody gwarantowania tajności przechowywanych i przesyłanych danych, czyli metody szyfrowania danych,
- metody gwarantowania wiarygodności danych, a więc niezmienności ich postaci i poświadczania ich autorstwa, czyli funkcje skrótu i podpisy cyfrowe.

Wyczerpujące informacje na temat prezentowanych poniżej zagadnień można znaleźć w wielu doskonałych pozycjach literatury, obecnych na rynku wydawniczym, takich jak na przykład prace Denning (1993), Schneidera (1995) lub Kippenhahna (2000).

1. Klucze kryptograficzne

Stosowane współcześnie metody kryptograficznej ochrony danych bazują na założeniu jawności algorytmów przekształcania zabezpieczanej informacji. Oznacza to, że tajności lub autentyczności danych strzeże nie sposób, w jaki dane te są zabezpieczane, ale sekretna informacja, używana do przekształcania danych. Informacja ta, znana tylko osobom uprawnionym, nazywana jest **kluczem** algorytmu kryptograficznego.

W metodach współczesnej kryptografii klucze to liczby — im są one dłuższe, tym lepiej zabezpieczają dane. W przypadku stosowanych obecnie algorytmów kryptograficznych, jedynym sposobem łamania zabezpieczeń strzegących informacji jest metoda prób i błędów (często określana terminem *atak brutalny*, od angielskiej nazwy *brute force attack*). Metoda prób i błędów to przeprowadzane na oślep sprawdzanie wszystkich potencjalnych kandydatów (liczb), mogących dać poszukiwane rozwiązanie. Liczba sprawdzeń niezbędnych do odgadnięcia właściwego klucza (dająca pojęcie o trudności złamania ochrony danych) jest łatwa do oszacowania. Jeżeli założymy, że klucz jest liczbą zapisaną w systemie liczbowym o podstawie B (dla systemu dziesiętnego $B = 10$, dla dwójkowego $B = 2$ itp.), to liczba wszystkich możliwych kluczy o długości M-cyfr wynosi:

$$N = B^M.$$

Jak widać, liczba ta rośnie wykładniczo, wraz ze wzrostem długości klucza, czyli wydłużenie klucza o jedną pozycję zwiększa B-krotnie pulę możliwych kluczy. Liczność zbiorów kluczy binarnych (a więc liczb zapisanych w systemie dwójkowym) o różnych długościach została przedstawiona w tabeli 1.

Tabela 1. Liczby kluczy binarnych o danej długości

Długość klucza	Liczba kluczy (N)	Długość klucza	Liczba kluczy (N)
$M = 1$	2	$M = 16$	65 536
$M = 2$	4	$M = 32$	4 294 967 296
$M = 3$	8	$M = 64$	$1{,}84 \cdot 10^{19}$
$M = 4$	16	$M = 128$	$3{,}4 \cdot 10^{38}$
$M = 8$	256	$M = 256$	$1{,}16 \cdot 10^{77}$

Osoba podejmująca próbę ataku na chronioną kryptograficznie wiadomość, musi dokonać przeszukania puli wszystkich możliwych kluczy. Zakładając, że ma ona przeciętne szczęście, wymaga to wykonania $N/2$ sprawdzeń klucza (gdzie N jest liczbą wszystkich kluczy). Aby oszacować czas potrzebny do złamania ochrony, konieczne jest dokładniejsze wyjaśnienie sensu zwrotu *sprawdzenie klucza*. Sprawdzenie klucza to wykonanie pełnego algorytmu kryptograficznego (na przykład deszyfracji danych), wykorzystującego rozważany w danej chwili klucz, a następnie analiza uzyskanego wyniku. Jeżeli wynik ten jest poprawny (na przykład uzyskano deszyfrację kryptogramu lub podrobiono podpis cyfrowy), klucz zostaje odgadnięty, co kończy poszukiwania, w przeciwnym przypadku konieczne jest sprawdzenie następnego klucza. Sprawdzenie klucza i analiza wyniku sprawdzenia są operacjami skomplikowanymi, zajmującymi zwykle kilka, kilkadziesiąt tysięcy taktów zegara procesora komputera, na którym są realizowane obliczenia. Szacowane czasy potrzebne do złamania ochrony informacji zabezpieczanej kluczem o różnych długościach, obliczone przy założeniu, że procedura sprawdzenia pojedynczego klucza zabiera tysiąc taktów zegara, zostały przedstawione w tabeli 2. Zważywszy, że od początku istnienia wszechświata do dnia dzisiejszego upłynęło około $5 \cdot 10^{17}$ sekund, przedstawione liczby dają intuicyjny pogląd, co do poziomu bezpieczeństwa zapewnianego przez stosowane algorytmy ochrony danych, uzasadniając jednocześnie używany często zwrot *praktyczna nieprzełamywalność* ochrony danych. Zakładając, że milion komputerów z procesorami 4 GHz zostałoby w chwili powstania wszechświata zaprzęgniętych do zadania odgadywania klucza, zadanie to zostałoby rozwiązane do chwili obecnej jedynie dla przypadku kluczy o długości około 100 bitów.

Tabela 2. Czasy łamania kluczy o różnych długościach

Długość klucza	Oczekiwany czas odgadnięcia: jeden komputer z zegarem 4GHz	Oczekiwany czas odgadnięcia: milion komputerów z zegarem 4GHz
$M = 8$	0,000064 sekundy	0,000000000064 sekundy
$M = 32$	1,19 godziny	0.004 sekundy
$M = 56$	571 lat	5 godzin
$M = 64$	146 235 lat	53 dni
$M = 96$	$2,5 \cdot 10^{15}$ lat	2 512 308 552 lat
$M = 128$	$1,08 \cdot 10^{25}$ lat	$1,08 \cdot 10^{19}$ lat
$M = 256$	$3,67 \cdot 10^{63}$ lat	$3.67 \cdot 10^{57}$ lat

Pewnego komentarza wymaga sens rozważania czasu łamania klucza przy użyciu wielkiej liczby komputerów (trzecia kolumna tabeli 2). Zachodzi pytanie, czy założenie, że dysponuje się taką armią maszyn nie jest ograniczone wyłącznie do jakiejś gigantycznej instytucji, która może sobie pozwolić na odpowiedni wydatek (i jednocześnie zgodzić się na zaabsorbowanie całego stanu posiadania w dość beznadziejne zadanie odgadywania klucza). Otóż, okazuje się, że powyższe założenie jest bardzo realistyczne, bowiem dysponentem ogromnej liczby komputerów może stać się jedna, odpowiednio sprytna osoba. Mechanizm opanowywania wielkiej liczby komputerów jest dość prosty — wystarczy postępować według następującego przepisu:

1) należy napisać program, pełniący pożyteczną i powszechnie pożądaną funkcję (na przykład możliwości przeprowadzania pogawędek w Internecie),
2) następnie należy umieścić w programie dodatkową, ukrytą funkcję (na przykład sprawdzanie kluczy), która działa w tle,
3) w końcu trzeba rozpowszechnić program w Internecie — jako darmowe, ogólnodostępne narzędzie.

Magia darmowego produktu powinna szybko zrobić swoje, doprowadzając do masowego upowszechnienia się programu między użytkownikami Internetu. Ponieważ przedstawiony scenariusz nie może zostać zignorowany, ostatnia kolumna tabeli 2 zawiera dane stanowiące faktyczne przesłanki do określania minimalnych długości kluczy, które zapewnią skuteczną ochronę zabezpieczanej informacji. Oszacowania przedstawione w tabeli 2 bazują na założeniu, że złamanie ochrony danych (np. złamanie szyfru lub podrobienie podpisu cyfrowego) jest dokonywane przez wspomniane wcześniej „sprawdzanie" klucza. Okazuje się, że w przypadku niektórych technik kryptograficznych przedmiotem ataku mogą być pewne wielkości związane z atakowanym kluczem, co sprawia, że klucze o danej długości niekoniecznie dają tak dobrą ochronę, jak wynikałoby to z tabeli 2. Dotyczy to na przykład zagadnienia łamania szyfru RSA, gdzie przedmiotem ataku jest tzw. faktoryzacja liczby pierwszej (rozkład liczby pierwszej na czynniki), a nie podejmowanie prób deszyfracji wiadomości przy użyciu kolejnych kluczy. Dlatego też długości kluczy uznawanych za bezpieczne są określane w powiązaniu ze stosowaną techniką szyfrowania i możliwymi do użycia technikami łamania ochrony kryptograficznej.

Podstawowym celem ataku na szyfr nie jest odgadnięcie zaszyfrowanej wiadomości czy też podrobienie podpisu cyfrowego, ale odgadnięcie klucza, który został użyty do zapewnienia ochrony danych. Oczywiście, osiągnięcie wspomnianego celu pobocznego może być niezmiernie ważne, jednak dopiero wejście w posiadanie cudzego sekretu daje atakującemu pełne panowanie nad wymianą informacji. W kryptografii wyróżnia się trzy rodzaje ataków na ochronę danych:

1) atak bez tekstu jawnego — stanowi on próbę odgadnięcia klucza w sytuacji, w której atakujący dysponuje tylko i wyłącznie informacją przetworzoną algorytmem kryptograficznym (np. zaszyfrowanym tekstem);
2) atak z tekstem jawnym — różni się od poprzedniego tym, że atakujący jest dodatkowo w posiadaniu informacji oryginalnej (ma więc do dyspozycji zarówno tekst jawny, jak i powstały z niego kryptogram);
3) atak ze spreparowanym tekstem jawnym — atakujący sam przygotowuje tekst, który ma podlegać ochronie, podsuwa go jako argument operacji zabezpieczania (np. zaszyfrowania) oraz wchodzi w posiadanie utworzonego kryptogramu. Informacja, którą przygotowuje atakujący jest spreparowana tak, aby uderzyć w najsłabsze punkty algorytmu szyfrującego. Najgłośniejszym przypadkiem przeprowadzenia skutecznego ataku kryptograficznego ze spreparowanym tekstem jawnym było złamanie w czasie II wojny światowej japońskiego szyfru Purple, dzięki czemu możliwe stało się amerykańskie zwycięstwo w bitwie pod Midway, odwracające koleje wojny na Pacyfiku.

Założeniem przyjętym przy opracowywaniu współczesnych technik kryptograficznych była konieczność zapewnienia odporności metod ochrony danych na atak ze spreparowanym tekstem jawnym, a więc sytuacja najbardziej korzystna z punktu widzenia atakującego. Przyjmuje się, że wszystkie stosowane obecnie metody kryptograficzne są odporne na ataki ze spreparowanym tekstem jawnym i zapewniają bezpieczeństwo o stopniu będącym wyłącznie funkcją długości klucza kryptograficznego, używanego do ochrony danych. Oznacza to, że jeżeli posiadany przez nas klucz nie zostanie ujawniony, można być pewnym (przynajmniej w stosunku do większości algorytmów szyfrowania), że nikt nie będzie w stanie złamać zastosowanej przez nas ochrony danych.

2. Ochrona tajności danych — algorytmy szyfrowania

Celem szyfrowania danych jest ich utajnienie, tak aby informacje mogły być wymieniane jedynie między osobami znającym odpowiedni sekret — klucz. Istnieją dwie podstawowe grupy algorytmów szyfrowania: szyfry z kluczem symetrycznym i szyfry z kluczem asymetrycznym. W pierwszym przypadku klucz używany do zaszyfrowania danych jest identyczny jak klucz wymagany do ich odszyfrowania. Ponieważ obydwie strony są w posiadaniu tej samej tajnej informacji, systemy szyfrowania symetrycznego określa się często mianem systemów ze współdzielonym sekretem. W algorytmach szyfrowania asymetrycznego klucze szyfrowana i deszyfracji wiadomości są różne i znajdują się w posiadaniu różnych osób (nie ma współdzielenia sekretu). Algorytmy szyfrowania asymetrycznego są często nazywane algorytmami klucza publicznego.

Algorytmy szyfrowania symetrycznego

Istotą algorytmów szyfrowania symetrycznego jest zamiana tekstu jawnego w tekst tajny (**kryptogram**), w drodze stosowania podstawień i przestawień. Podstawienia to zamiana znaków tekstu jawnego na inne znaki, według określonej zasady. Przestawienia to zamiana kolejności znaków tekstu jawnego, dokonywana również według określonego schematu. Sposób, według którego dokonywane są podstawienia, jak i sposób realizacji przestawień zależą od klucza szyfrowania, który jest taki sam dla szyfrowania i deszyfracji wiadomości. Podział algorytmów szyfrowania symetrycznego — według zasady utajniania wiadomości — na szyfry podstawieniowe i szyfry przestawieniowe, jest podstawowym sposobem klasyfikacji metod kryptografii symetrycznej, chociaż ma on znaczenie raczej historyczne, obecnie używane szyfry wykorzystują bowiem zwykle kombinację obydwu technik.

Metody szyfrowania symetrycznego

Szyfrowanie danych metodami podstawieniowymi to zastępowanie znaków tekstu jawnego znakami kryptogramu, według pewnej zasady wykorzystującej współdzielony sekret. Zasada, według której zastępujemy znaki, może być — w najprostszym przypadku — przedstawiona za pomocą tzw. tabliczki kodowania, przedstawionej na rysunku 1. Tabliczka kodowania zawiera dwa ciągi znaków skojarzonych w pary — dolne znaki używane są do zastępowania znaków górnych. Szyfrowanie i deszyfracja to zamiana kolejnych znaków tekstu na symbole, wynikające z używanej tabliczki kodowania. Przykładowo, tekst *mama*, zaszyfrowany zgodnie z tabliczką kodowania z rysunku 1, da w wyniku kryptogram *żmżm*.

a	ą	b	c	ć	d	e	ę	f	g	h	i	j	k	l	ł	m	n	ń	o	ó	p	r	s	ś	t	u	w	x	y	z	ź	ż
m	n	ń	o	ó	p	r	s	ś	t	u	w	x	y	z	ź	ż	a	ą	b	c	ć	d	e	ę	f	g	h	i	j	k	l	ł

Rysunek 1. Przykładowa tabliczka kodowania

Dokładniejsza analiza rysunku 1 prowadzi do stwierdzenia, że przedstawiona tam zasada kodowania liter nie jest przypadkowa — ciąg znaków służący do zastępowania znaków tekstu jawnego stanowi przesunięcie ciągu oryginalnego. Szyfry konstruowane według tej zasady nazywane są szyframi Cezara, którego uważa się za autora tej metody kodowania. Sekretem współdzielonym między stroną szyfrującą a odbiorcą wiadomości jest w szyfrze Cezara wartość przesunięcia ciągu znaków, wynosząca w podanym przykładzie 17 pozycji. Szyfr Cezara ma znaczenie wyłącznie historyczne, a jego złamanie jest bardzo proste — aby odczytać zaszyfrowaną wiadomość wystarczy wypróbować wszystkie możliwe przesunięcia ciągu znaków alfabetu (których, dla przedstawionego alfabetu o 33 znakach, jest co najwyżej 32).

Kolejnym etapem w ewolucji szyfrów podstawieniowych było odejście od przedstawionej prostej reguły konstruowania tabliczek kodowania. Istotną innowacją stało się zwiększenie roli klucza szyfrowania, który wykorzystywany był do tworzenia tabliczek kodowania w następujący sposób: słowo lub zwrot stanowiący klucz było wpisywane na pierwsze pozycje dolnego wiersza tabliczki (bez powtarzania znaków), a reszta wiersza była zapełniana pozostałymi znakami alfabetu, niewystępującymi w zastosowanym sekrecie. Przykład tabliczek kodowania dla dwóch sekretów: słowa *pokrzywa* i zwrotu *kuj żelazo póki gorące* zostały przedstawione na rysunku 2, a zakodowane słowo *mama* ma postać *gpgp* dla pierwszego przypadku, zaś *bkbk* dla drugiego przypadku.

a	ą	b	c	ć	d	e	ę	f	g	h	i	j	k	l	ł	m	n	ń	o	ó	p	r	s	ś	t	u	w	x	y	z	ź	ż
p	o	k	r	z	y	w	a	ą	b	c	ć	d	e	ę	f	g	h	i	j	l	ł	m	n	ń	ó	s	ś	t	u	x	ź	ż

a	ą	b	c	ć	d	e	ę	f	g	h	i	j	k	l	ł	m	n	ń	o	ó	p	r	s	ś	t	u	w	x	y	z	ź	ż
k	u	j	ż	e	l	a	z	o	p	ó	i	g	r	ą	c	b	ć	d	ę	f	h	ł	m	n	ń	s	ś	t	w	x	y	ź

Rysunek 2. Tabliczki kodowania budowane przy wykorzystaniu różnych sekretów

Odgadnięcie zasady, według której zastępowane są kolejne znaki alfabetu, staje się zadaniem praktycznie niemożliwym do wykonania, gdy sekrety stają się odpowiednio

długie. Okazuje się jednak, że przedstawiony sposób szyfrowania jest marnym sposobem ochrony treści wiadomości, ponieważ łamanie szyfru wcale nie odbywa się w drodze odgadywania tabliczki kodowania. Metoda łamania omawianych szyfrów wykorzystuje charakterystyczną cechę każdego języka, którą są częstości, z jakimi występują kolejne znaki alfabetu. Przykładowo, w tekstach języka polskiego, najczęściej występującym znakiem jest litera *a* (stanowi średnio 7,3% przeciętnego tekstu), następnie litera *i* (6,9%), po niej litera *e* (6,4%) itd. Jeżeli chcemy złamać szyfr, wcale nie musimy odgadywać tabliczki kodowania — wystarczy przeanalizować kryptogram i określić częstości występowania kolejnych znaków. Znając te częstości, można z dużym prawdopodobieństwem powiedzieć, jakimi znakami kryptogramu są zastępowane poszczególne litery alfabetu (przykładowo, w tekście szyfrowanym tabliczkami kodowania z rys. 2 najczęściej pojawiającym się znakiem dla górnej tabliczki byłoby prawdopodobnie *p*, zaś szyfrowanym dolną tabliczką — litera *k*).

Wspólną cechą przedstawionych dotychczas sposobów szyfrowania było jednoznaczne przyporządkowanie konkretnemu znakowi tekstu jawnego jednego i tylko jednego znaku kryptogramu. Szyfry o takiej zasadzie kodowania nazywają się **szyframi podstawieniowymi monoalfabetycznymi**. Szyfry podstawieniowe monoalfabetyczne nie zapewniają dobrego utajniania danych i nie są stosowane w praktyce.

Aby wyeliminować podstawową słabość kodowania, ułatwiającą łamanie szyfrów na podstawie analizy częstości występowania znaków, konieczne jest wprowadzenie takiej metody szyfrowania, która pozwoli na przypisywanie danemu znakowi tekstu jawnego wielu możliwych „zamienników”. Szyfry budowane przez zastępowanie danego znaku tekstu jawnego różnymi znakami kryptogramu nazywane są **szyframi polialfabetycznymi**. W sytuacji, gdy dana litera alfabetu będzie kodowana różnymi znakami (np. litera *a* będzie zastępowana raz literą *o*, a kiedy indziej literą *r*) analiza częstości występowania znaków stanie się bezużyteczna, a złamanie szyfru będzie wymagało odgadnięcia zasady kodowania (czyli klucza).

Sposób wykorzystania klucza w szyfrach polialfabetycznych jest inny niż w szyfrach monoalfabetycznych. Tym razem klucz traktowany jest jako zbiór informacji, mówiących o sposobie kodowania kolejnych liter szyfrowanego tekstu (poprzednio klucz — przez tabliczkę kodowania — określał zasadę kodowania wszystkich liter alfabetu). Kolejne litery szyfrowanego tekstu są zastępowane w sposób zależny od kolejnych liter klucza. Przykładowo, jeżeli w kluczu pojawia się litera *a*, czyli pierwsza litera alfabetu, odpowiadający jej znak kodowanego tekstu będzie zastępowany literą położoną o jedną pozycję dalej (jeżeli w tekście było *s*, zostanie ono zastąpione przez *ś*). Jeżeli drugą literą

klucza jest *c*, to drugi znak szyfrowanego tekstu jest zastępowany literą o cztery pozycje dalszą (zamiast np. *i* będzie *ł*) itd. Jeżeli do zaszyfrowania tekstu *oko* użyjemy klucza *dąb*, uzyskamy w wyniku tekst *tłr*, powstały z: przesunięcia litery *o* o sześć znaków, litery *k* o dwa znaki i litery *o* o trzy znaki. Łatwo zauważyć, że ta sama litera wiadomości (czyli *o*) jest kodowana różnymi znakami w otrzymanym kryptogramie.

Przedstawiony mechanizm postępowania może prowadzić do uzyskania szyfru niemożliwego do złamania, jednakże, aby tak było, muszą być spełnione dwa warunki. Po pierwsze, klucz musi być dłuższy od szyfrowanej wiadomości (tak, aby każda z liter wiadomości mogła być zakodowana według innej zasady). Po drugie, klucz powinien być ciągiem zupełnie przypadkowych znaków (bliższe wyjaśnienia obydwu zagadnień można znaleźć we wspomnianych wcześniej pozycjach literatury). Zapamiętanie długiego klucza złożonego z przypadkowych znaków i jego efektywne używanie staje się trudne, dlatego też jednym ze sposobów wspomagania utajniania wiadomości stało się użycie maszyn, a najsłynniejszą maszyną do kodowania szyframi polialfabetycznymi stała się Enigma.

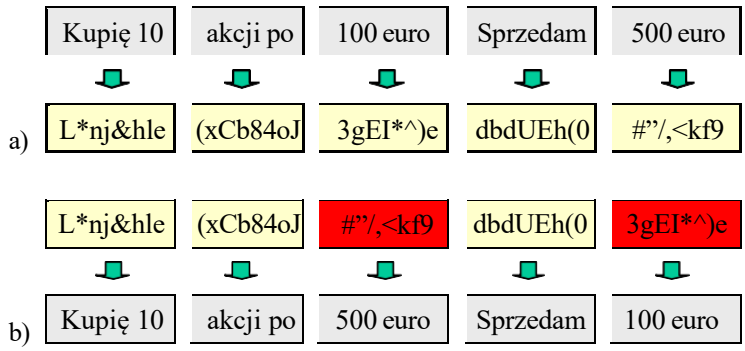
Drugą grupą szyfrów stosowanych do ochrony wiadomości stały się, obok szyfrów podstawieniowych, szyfry przestawieniowe. Istota utajniania wiadomości polega tu na zamianie miejscami liter tekstu, przy czym algorytm dokonywania zamian jest zwykle znany i zależny od sekretu, współdzielonego między stronami korespondencji.

Współczesne szyfry symetryczne

Wszystkie stosowane obecnie szyfry symetryczne stanowią kombinację szyfrów przestawieniowych i podstawieniowych. Pierwszym przyjętym powszechnie standardem szyfrowania symetrycznego był szyfr DES, opracowany w latach siedemdziesiątych XX wieku. Tekst podlegający szyfrowaniu przy użyciu algorytmu **DES** jest dzielony na ośmiobajtowe bloki danych, które są argumentem operacji przestawień i podstawień, zależnych od wykorzystywanego klucza szyfrowania. Klucze szyfrowania w algorytmie DES miały długość 56 bitów, co — zgodnie z tabelą 2 — zapewniało praktyczną nieprzełamywalność szyfru przy mocach obliczeniowych ówczesnych komputerów. Szybki postęp technologii i rozwój metod analizy szyfrów sprawił, że na początku lat 90-tych algorytm DES przestał stanowić wystarczającą ochronę dla szyfrowanych danych. Następcą algorytmu DES stał się algorytm **3DES**, stanowiący trzyetapową procedurę: szyfrowania, deszyfracji i ponownego szyfrowania, dokonywaną algorytmem DES z różnymi kluczami szyfrowania. Algorytm 3DES na dzień dzisiejszy daje skuteczną ochronę danych, ale w perspektywie kilku, kilkunastu lat może stać się możliwy do złamania. Dlatego też od kilku lat jako standard szyfrowania symetrycznego przyjęty został nowo opracowany szyfr o nazwie **AES** (ang. *Advanced Encryption Standard*,

oryginalna nazwa tego algorytmu, wymyślonego przez Holendrów, to Rijnadel). Algorytm ten, podobnie jak DES, operuje na blokach danych (tym razem 16-bajtowych), a szyfrowanie jest chronione kluczami, których długości mogą wynosić 128, 192 lub 256 bitów. Zgodnie z danymi tabeli 2, ochrona danych, jaką zapewnia szyfr AES, jeszcze przez długi czas będzie wystarczająca (o ile nie pojawią się nieznane w dniu dzisiejszym, zupełnie nowe metody łamania szyfrów). Dodatkową zaletą algorytmu AES jest zbudowanie go na czytelnych podstawach matematycznych, dających pewność „uczciwości" algorytmu. „Uczciwość" algorytmu to brak ogólnie nieznanych mechanizmów łamania szyfru, na przykład pewnych kluczy lub ich kombinacji, pozwalających na odczytanie wiadomości zabezpieczanej innym, dowolnym kluczem. W odniesieniu do algorytmu DES (a także algorytmu 3DES) pewność jego uczciwości nigdy nie istniała, bowiem informacje, które wyjaśniają to, skąd biorą się przekształcenia stosowane w algorytmie, są do dnia dzisiejszego objęte pełną tajemnicą.

Zarówno algorytm 3DES, jak i AES są algorytmami szyfrującymi kolejne bloki danych (nazywa się je w związku z tym algorytmami szyfrowania blokowego). Efektem zaszyfrowania bloku danych o danej długości jest kryptogram o niezmienionej liczbie znaków. Szyfrowanie całej wiadomości to podział tekstu na bloki i szyfrowanie kolejnych bloków (rys. 3a).



Rysunek 3. Szyfrowanie blokowe (a) i potencjalne zagrożenie dla prostego schematu szyfrowania wieloblokowych wiadomości (b)

Jeżeli do szyfrowania używamy dostatecznie długiego klucza, kryptogram jest niemożliwy do odczytania przez osoby postronne. Niestety, nie oznacza to jeszcze, że udało nam się zapewnić danym dostateczną ochronę. Problem tkwi w możliwości modyfikacji wiadomości przez atakującego, która wcale nie wymaga łamania szyfru. Ponieważ bloki szyfrowane są niezależnie od siebie, łatwo zauważyć, że możliwa jest zmiana

przekazywanej przez nas wiadomości przez przestawianie lub dodawanie bloków (rys. 3b). Ponieważ operacje takie mogą zostać przez nas niezauważone, procedury szyfrowania często stosują metodę tzw. wiązania bloków, uniemożliwiającą przeprowadzenie przedstawionego ataku. Idea postępowania polega na uzależnieniu procedury szyfrowania kolejnych bloków wiadomości od wyniku szyfrowania bloku poprzedniego. Konkretny sposób uzależniania może być różny — przykładowo, zanim przystąpi się do szyfrowania drugiego bloku wiadomości, można przekształcić ten blok przy użyciu operacji wykorzystującej wynik szyfrowania pierwszego bloku. Podobnie trzeci blok jest przekształcany na podstawie wyników szyfrowania etapu drugiego itd. Przedstawiony sposób postępowania określa się często terminem *wiązanie bloków*, zaś metoda szyfrowania nazywa się CBC (ang. *Circular Block Chaining*). Metoda CBC jest często stosowanym podejściem w szyfrowaniu wiadomości metodami 3DES lub AES, zapewniając ochronę oryginalnej formy wiadomości. Inna, powszechnie stosowana technika ochrony oryginalnej formy danych zostanie przedstawiona w dalszej części prezentowanego materiału.

3. Szyfrowanie danych metodami asymetrycznymi

Szyfrowanie danych przy użyciu współczesnych szyfrów symetrycznych, w których dwie strony komunikacji korzystają z takiego samego, współdzielonego klucza, zapewnia pełną ochronę tajności przekazywanych wiadomości. Metody szyfrowania symetrycznego mają jednak jedną poważną wadę — współodpowiedzialność za bezpieczeństwo sekretu. Nawet, gdy jedna ze stron komunikacji dołoży wszelkich starań, aby zapewnić bezpieczeństwo używanego przez nią klucza, nie może mieć pewności, że tak samo poważnie do ochrony sekretu podchodzi partner komunikacji. Dlatego też pojawiła się konieczność opracowania takich metod szyfrowania, w których tajność korespondencji zależy od sekretu znanego tylko i wyłącznie jednej osobie, czyli metod używających do utajniania wiadomości innego klucza niż do jej deszyfracji. Konkretne wymagania postawione pożądanemu systemowi kryptograficznemu były następujące:

1) klucze szyfrowania i deszyfracji muszą być różne,
2) wiadomość zaszyfrowana jednym z kluczy stanowiących parę może być odszyfrowana tylko i wyłącznie przy użyciu drugiego klucza z pary (w szczególności wiadomość zaszyfrowana danym kluczem nie może być odszyfrowana tym samym kluczem),
3) znajomość jednego klucza z rozważanej pary nie pozwoli na odgadnięcie drugiego.

Pierwsza metoda spełniająca przedstawione założenia została opracowana w latach siedemdziesiątych ubiegłego wieku przez trzech kryptoanalityków: Rivesta, Shamira i Adlemana i od pierwszych liter ich nazwisk została nazwana metodą **RSA**. Opracowanie metody RSA otworzyło drogę do powszechnego stosowania handlu elektronicznego, bankowości elektronicznej i poświadczania autentyczności. W chwili obecnej istnieje jeszcze kilka innych metod szyfrowania, spełniających przedstawione wymagania, a z uwagi na wykorzystanie w nich do szyfrowania i deszyfracji danych różnych kluczy, są one klasyfikowane jako **metody szyfrowania asymetrycznego**.

W przeciwieństwie do większości stosowanych metod szyfrowania symetrycznego, przekształcanie danych w algorytmie RSA oparte jest na dobrze ugruntowanej teorii, dzięki której można mieć pewność „uczciwości" szyfru. Oznaczając ciąg danych literą **X**, a kryptogram literą **Y**, zasadę szyfrowania danych metodą RSA można przedstawić w następującej postaci ogólnej:

$$\mathbf{Y} = f_s(\mathbf{X}), \qquad \mathbf{X} = f_d(\mathbf{Y})$$

Występujące w powyższych zależnościach funkcje to funkcja szyfrująca dane (f_s) i funkcja deszyfrująca dane (f_d). W algorytmie RSA funkcje te mają identyczną postać:

$$y = x^j \oplus n \qquad (1a)$$

$$x = y^t \oplus n \qquad (1b)$$

gdzie symbol $\oplus$ oznacza resztę z dzielenia (nazywaną często „operacją modulo"). Argumenty operacji: *x* i *y* to liczby odpowiadające ciągom znaków **X** i **Y**. Wykładniki potęg we wzorach: *j* i *t* to odpowiednio dobrane liczby naturalne, podobnie jak liczba *n*. Szyfrowanie danych metodą RSA to przekształcenie argumentu *x* w wynik *y*, wykorzystujące liczbę *j*, którą można w tym przypadku uznać za klucz szyfrowania. Deszyfracja to odtworzenie oryginalnej liczby *x* z kryptogramu *y*, przy wykorzystaniu liczby *t*, którą można uznać za klucz deszyfracji. Równości (1) zachodzą tylko wtedy, gdy liczby *j*, *t* i *n* spełniają pewne określone zależności (dokładna procedura określania tych liczb może zostać znaleziona np. w pracy Denning z 1993 r.).

Przykład 1

Załóżmy, że parametry RSA to: $n = 49$, $j = 11$, zaś $t = 23$. Zaszyfrujmy za pomocą algorytmu RSA słowo *boa*. Pierwszym etapem szyfrowania jest zamiana szyfrowanych znaków na liczby (argumentami operacji szyfrowania są liczby). W ogólnym przypadku zamiana znaku na liczbę polega na zastąpieniu znaku odpowiadającym mu kodem ASCII (np. litera *a* jest reprezentowana przez liczbę 97 itp.). W przedstawionym uproszczonym przykładzie przyjmijmy, że liczba reprezentująca literę to numer tej litery w alfabecie (jednym z wymagań szyfrowania jest to, aby szyfrowana liczba nie była większa niż liczba *n*, dlatego też użycie kodu ASCII jest w przykładzie niemożliwe). Dla alfabetu polskiego, tekst *boa* zostanie więc zamieniony na ciąg liczb 3, 20, 1. Procedura szyfrowania to wykonanie następujących operacji:

— szyfrowanie znaku *b*: $y = 3^{11} \oplus 49 = 37$,

— szyfrowanie znaku *o*: $y = 20^{11} \oplus 49 = 34$,

— szyfrowanie znaku *a*: $y = 1^{11} \oplus 49 = 1$.

Efektem szyfrowania jest ciąg liczb 37, 34, 1. Deszyfracja tego ciągu to wykonanie następujących trzech operacji, dających oryginalne wartości liczb:

$$y = 37^{23} \oplus 49 = 3 \qquad y = 34^{23} \oplus 49 = 20 \qquad y = 1^{23} \oplus 49 = 1$$

Równania (1) to przekształcenia, których złożenie jest tożsamością (to znaczy przekształcenie liczby *x* przy użyciu równania (1a), po którym następuje przekształcenie uzyskanego wyniku przy użyciu równania (1b), daje w efekcie liczbę *x*). Okazuje się, że złożenie tych przekształceń w odwrotnej kolejności, a więc wykonanie kolejno operacji przekształcenia liczby, wykorzystującego parametry *t* i *n*, a następnie, przekształcenia wykorzystującego *j* i *n*, jest również tożsamością, a więc daje w wyniku liczbę *x*:

$$z = x^t \oplus n \qquad (2a)$$

$$x = z^j \oplus n \qquad (2b)$$

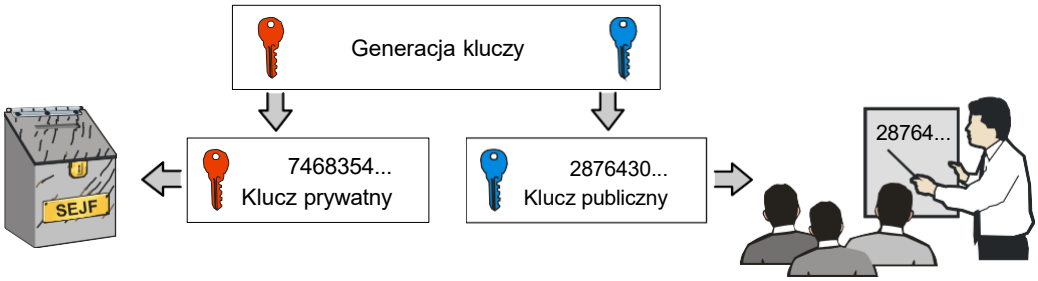
Oznacza to, że liczba *t* może być użyta jako klucz szyfrowania, w wyniku którego uzyskamy kryptogram *z*, zaś liczba *j* może być następnie użyta do deszyfracji tego kryptogramu. Analizując zależności (1) i (2) można zauważyć, że nazywanie jednego z parametrów *t*, *j* kluczem szyfrowania lub kluczem deszyfracji jest czysto umowne. Ważne jest to, że liczby te stanowią parę o następującej fundamentalnej właściwości: jeżeli tekst będzie zaszyfrowany przy użyciu jednej z nich, może on zostać odszyfrowany tylko przy użyciu drugiej.

Korzystanie z kryptosystemu RSA

Pierwszą czynnością, którą wykonuje osoba, chcąca uczestniczyć w komunikacji szyfrowanej metodą RSA, jest generacja liczb *t*, *j* i *n*, czyli generacja kluczy szyfrowania. W przeciwieństwie do algorytmów szyfrowania symetrycznego, gdzie dowolna liczba losowa może być kluczem szyfrowania, utworzenie kluczy szyfrowania RSA jest operacją dość złożoną. Stosowane obecnie długości kluczy RSA to minimum 1024 bity (odpowiada to liczbie o mniej więcej 300 pozycjach), co zapewnia praktyczną nieprzełamywalność szyfrów. Rozmiary kluczy w RSA są znacznie większe niż w algorytmach szyfrowania symetrycznego, ponieważ sposób ataku na szyfr RSA odbywa się w nieco inny sposób (w chwili obecnej możliwe jest złamanie szyfru RSA chronionego kluczami o długościach około 500–600 bitów).

Liczby *t*, *j* i *n*, po ich generacji, są następnie traktowane w różny sposób (rys. 4). Para liczb *j* i *n* zostaje przekazana do publicznej wiadomości i jest nazywana **kluczem publicznym** (lub **kluczem jawnym**). Klucz publiczny może być wykorzystany do szyfrowania korespondencji przeznaczonej dla osoby, która go wygenerowała (zgodnie z równaniem (1a)) lub deszyfracji wiadomości utworzonych przez tę osobę (zgodnie z równaniem (2b)). Para liczb *t*, *n* stanowi tajny sekret i jest zapamiętywana przez generującego klucze w chronionym, niedostępnym dla nikogo miejscu. Sekret ten jest nazywany **kluczem prywatnym** (lub **kluczem tajnym**) i może być wykorzystywany do

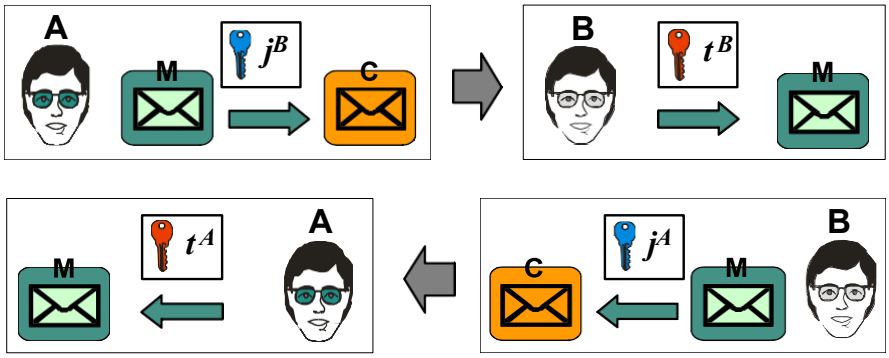
szyfrowania wiadomości sporządzanej przez posiadacza klucza (równanie (2a)) lub deszyfracji danych adresowanych do posiadacza klucza (równanie (1b)). Kryptografia klucza asymetrycznego, czyli metoda szyfrowania i deszyfracji danych, korzystająca z różnych kluczy, jest często nazywana **kryptografią klucza publicznego**.



Rysunek 4. Procedura generacji kluczy systemu RSA

Rozważmy procedurę szyfrowania danych w metodzie RSA. Załóżmy, że mamy dwie strony komunikacji — osoby A i B, które wygenerowały wcześniej swoje pary kluczy kryptograficznych. Dodatkowo, obydwie osoby rozgłosiły swoje klucze publiczne (każdy, w tym partnerzy komunikacji, mógł wejść w ich posiadanie), jednocześnie ukrywając swoje klucze prywatne tak, aby nikt inny nie mógł z nich korzystać. Procedura szyfrowania wiadomości przesyłanych między A i B będzie następująca (rys. 5):

- Osoba A szyfruje wiadomość M, którą chce wysłać do osoby B kluczem publicznym osoby B, oznaczonym przez j^B (oblicza równanie (1a)). Uzyskany w wyniku kryptogram C jest wysyłany do osoby B.
- Osoba B otrzymuje kryptogram C, pobiera przechowywany przez siebie w tajnym miejscu klucz prywatny t^B i odtwarza wiadomość oryginalną. Ponieważ tylko ona posiada klucz prywatny, jest pewna, że nikt kto wszedł w posiadanie zaszyfrowanej wiadomości nie był w stanie jej odczytać.
- Podobnie, dla utajnienia komunikacji w przeciwnym kierunku, osoba B szyfruje wiadomości wysyłane do osoby A kluczem publicznym osoby A (j^A); osoba A odszyfrowuje otrzymane kryptogramy swoim kluczem prywatnym (t^A).



Rysunek 5. Szyfrowanie komunikacji w systemie RSA

Przedstawiona procedura komunikacji zapewnia ochronę tajności przesyłanych danych. Nikt postronny nie będzie w stanie odczytać wymienianych wiadomości. Podstawową różnicą w stosunku do procedur szyfrowania symetrycznego jest brak współdzielonego sekretu — obydwie strony komunikacji są jedynymi posiadaczami swoich kluczy prywatnych, używanych w przedstawionej procedurze do deszyfracji wiadomości.

Skoro szyfr RSA pozwala na skuteczną ochronę tajności danych i jest wolny od wady szyfrów symetrycznych, jaką jest współdzielenie odpowiedzialności za przechowywanie sekretu, rodzi się pytanie, dlaczego nie wyparł on całkowicie z użycia metod szyfrowania symetrycznego? Przyczyną, dla której szyfry symetryczne nadal znajdują się (i będą się znajdować) w powszechnym użyciu jest złożoność obliczeniowa procedur szyfrowania i deszyfracji danych, która dla algorytmu RSA jest zdecydowanie większa niż dla szyfrów symetrycznych. Różnica ta wynosi 2–3 rzędy wielkości na niekorzyść RSA, co sprawia, że w zastosowaniach, w których zależy na szybkości działania (np. bezpieczna komunikacja on-line między komputerami) zastosowanie szyfrowania symetrycznego dla ochrony danych staje się konieczne.

Kryptografia klucza publicznego, oprócz możliwości szyfrowania danych, pozwala na gwarantowanie wiarygodności przesyłanych danych, co zostanie bliżej wyjaśnione w dalszej części kursu.

4. Metody ochrony wiarygodności danych

Wiarygodność danych to pewność, że dane mają niezmienioną postać w stosunku do postaci oryginalnej (a więc nie zostały zmodyfikowane) oraz pewność, że zostały one rzeczywiście sporządzone przez osobę podającą się za ich autora. W pierwszym przypadku mówimy o **integralności** danych, w drugim zaś — o **niepodważalności autorstwa** danych.

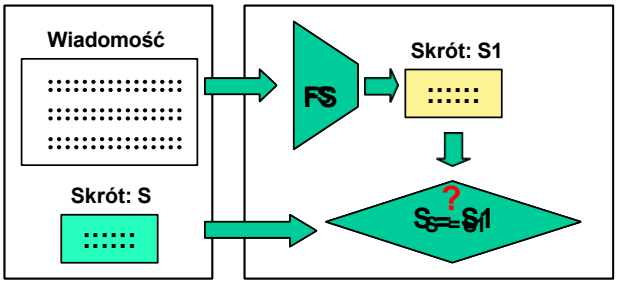
4.1. Ochrona integralności danych

Ochrona integralności (spójności) danych to działanie mające na celu wykrywanie wszelkich zmian, które mogły w nich zostać dokonane. Modyfikacje danych mogą być wynikiem świadomego działania osoby niepowołanej lub też rezultatem pojawiania się błędów transmisji czy odczytu/zapisu danych. Istotą metod detekcji zmian dokonywanych w danych jest dołączanie do danych dodatkowej informacji, nazywanej czasami „odciskiem palca" danych, niosącej pełną wiedzę o oryginalnym kształcie chronionych informacji. Skuteczna realizacja ochrony integralności danych wymaga spełnienia kilku istotnych warunków. Po pierwsze, informacja dołączana do danych powinna mieć stosunkowo niewielki rozmiar, a sama procedura sprawdzenia integralności powinna być możliwie szybka. Po drugie, „odcisk palca" wiadomości powinien być unikatowy dla każdej wiadomości, tak jak prawdziwy odcisk palca jednoznacznie identyfikuje człowieka. Jest to konieczne po to, aby każda, przypadkowa lub celowa modyfikacja danych mogła zostać wykryta. Trzecim wymaganiem, jakie zostało określone dla dodatkowej informacji zabezpieczającej integralność danych jest warunek niemożliwości odtworzenia na jej podstawie chronionego tekstu.

Metody, które zostały opracowane w celu ochrony integralności danych nazywane są **funkcjami skrótu** lub funkcjami mieszającymi (ang. *hash functions*). Używane obecnie powszechnie funkcje skrótu — **MD** (od ang. *Message Digest*, czyli funkcja „przetrawiania" wiadomości) i **SHA** (od ang. *Secure Hash Algorithm*, czyli bezpieczny algorytm skrótu) są algorytmami spełniającymi sformułowane powyżej założenia. Obydwie funkcje skrótu są funkcjami jednokierunkowymi, a więc takimi, które nie posiadają funkcji odwrotnej (co realizuje postulat niemożliwości odgadnięcia tekstu na podstawie posiadanego skrótu). Skróty różnych wiadomości są zwykle zupełnie różne (nawet, gdy wiadomości są do siebie bardzo podobne, na przykład wielostronicowe teksty różnią się jednym przecinkiem, obliczone dla nich skróty są do siebie całkowicie niepodobne). Obliczenie

skrótu danej wiadomości polega na podziale tej wiadomości na bloki o stałej długości i wykonywaniu wielokrotnych przekształceń tych bloków. Efektem jest uzyskanie ciągu wynikowego o długości niezależnej od rozmiaru przekształcanej wiadomości, wynoszącego 20 bajtów (160 bitów) w przypadku zastosowania algorytmu SHA-1, zaś 16 bajtów (128 bitów) w przypadku zastosowania algorytmu MD4 lub MD5.

Procedura ochrony integralności wiadomości z wykorzystaniem funkcji skrótu została podsumowana na rysunku 6. Ochraniana wiadomość jest przechowywana lub przesyłana razem z wyznaczonym dla niej skrótem. Sprawdzenie, czy tekst wiadomości nie uległ zmianie polega na ponownym wyznaczeniu skrótu dla badanego tekstu i porównaniu go ze skrótem wcześniej utworzonym. Jeżeli porównywane skróty będą różne, będzie to oznaczać, że badany tekst jest inny niż tekst oryginalny, czyli że miała miejsce modyfikacja wiadomości.



Rysunek 6. Sprawdzanie integralności wiadomości (FS — funkcja skrótu)

4.2. Ochrona integralności przy użyciu współdzielonego sekretu

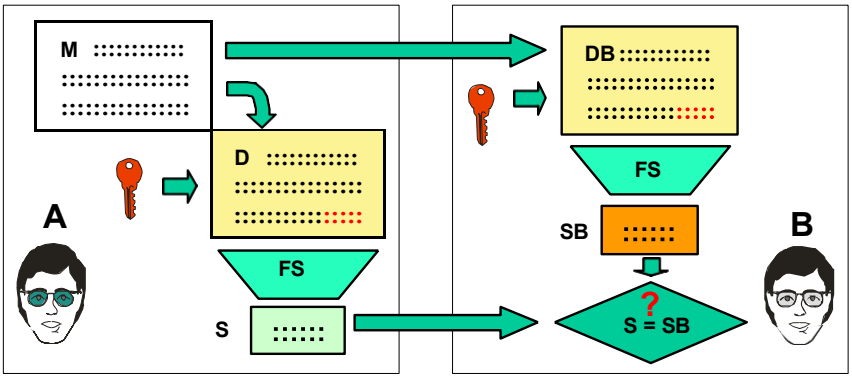
Zastosowanie funkcji skrótu, przedstawione w poprzedniej części, nie stanowi skutecznej ochrony przed celową modyfikacją danych. Jeżeli oszust zamierza zmodyfikować dane, może on również wyznaczyć skrót spreparowanej przez siebie wiadomości (algorytmy wyznaczania skrótu są powszechnie znane) i zastąpić nim skrót sporządzony dla wiadomości oryginalnej. Osoba sprawdzająca, mając do dyspozycji zmodyfikowane dane i podstawiony skrót nie jest w stanie wykryć oszustwa.

Podobnie jak miało to miejsce w przypadku szyfrowania wiadomości, skuteczne zabezpieczenie wiadomości przed sfałszowaniem wymaga wykorzystania sekretnych informacji. Najprostszym sposobem ochrony wiadomości jest wykorzystanie procedury odpowiadającej szyfrowaniu symetrycznemu, bazującej na sekrecie (kluczu) współdzielonym między uczestnikami komunikacji. Procedura zapewnienia integralności

wiadomości sporządzonej przez osobę A i przeznaczonej dla osoby B, wykorzystująca funkcję skrótu i sekret (klucz) współdzielony między A i B, składa się z następujących etapów (rys. 7):

1. Osoba A tworzy tymczasowy dokument D, zawierający sporządzoną przez siebie wiadomość M, do której dopisuje w umówiony sposób (na przykład na końcu) współdzielony sekret.
2. Osoba A tworzy skrót S tymczasowego dokumentu D (a nie oryginalnej wiadomości M) i dołącza go do wiadomości M.
3. Osoba B pobiera przeznaczone dla niej informacje, a więc skrót S i wiadomość M.
4. Osoba B sprawdza, czy skrót S został rzeczywiście wyznaczony na podstawie wiadomości M przez osobę A. W tym celu tworzy tymczasowy dokument DB, zawierający wiadomość M i współdzielony sekret, dołączony do M w umówiony sposób. Dla tak przygotowanego dokumentu tworzy skrót SB i porównuje go z otrzymanym skrótem S. Jeżeli obydwa są jednakowe, oznacza to, że wiadomość jest autentyczna, tzn. po pierwsze, jej treść nie została zmieniona i po drugie — jej autorem jest współposiadacz klucza (osoba A).

Przedstawiona procedura będzie chronić wiadomości przed sfałszowaniem przez osobę niepowołaną, która nie zna współdzielonego sekretu. Aby oszustwo było możliwe, osoba która chce zmodyfikować wiadomość musi dołączyć do niej podrobiony skrót. Skoro jednak osoba taka nie zna sekretu współdzielonego między A i B, nie będzie w stanie utworzyć odpowiedniego dokumentu D, czyli nie będzie w stanie obliczyć odpowiedniego skrótu. Rozumowanie takie jest słuszne tylko wtedy, gdy stosowana funkcja skrótu jest rzeczywiście jednokierunkowa (co zachodzi dla używanych obecnie algorytmów MD i SHA). Jeżeli funkcja nie byłaby jednokierunkowa, fałszerz mógłby wykonać przekształcenie odwrotne i ze skrótu wyznaczyć dokument D, zawierający w sobie współdzielony sekret.



Rysunek 7. Uwierzytelnianie wiadomości z wykorzystaniem współdzielonego sekretu. Blok FS to blok wyznaczania funkcji skrótu

Przedstawiona procedura zabezpieczania wiadomości nazywa się metodą generacji kodu uwierzytelniającego wiadomość — MAC (ang. *Message Authentication Code*). Jedynym znanym sposobem łamania przedstawionego sposobu ochrony jest metoda prób i błędów, a więc im dłuższy jest współdzielony klucz, tym trudniejsza do podrobienia staje się wiadomość.

5. Ochrona wiarygodności danych metodami kryptografii asymetrycznej

Przedstawiona w poprzednim temacie metoda ochrony integralności danych, wykorzystująca współdzielony między stronami komunikacji sekret, daje pewność, że ten, kto nie posiada klucza, nie będzie w stanie ani zmienić wiadomości, ani jej spreparować. Zachodzi więc pytanie: czy wykorzystanie przedstawionego schematu postępowania nie wystarczy do zagwarantowania wiarygodności wiadomości, a więc zarówno integralności, jak i niepodważalności autorstwa danych? Skoro tylko posiadacz sekretu potrafi sporządzić skrót wiadomości, powinno to wystarczyć do jednoznacznej identyfikacji jej autora. Okazuje się, że przedstawiona procedura zawiera poważną lukę, wykluczającą możliwość jej wykorzystania do uwierzytelniania autorstwa danych.

Rozważmy przypadek, w którym dwie strony komunikacji to bank i klient tego banku, który posiada internetowy dostęp do swojego konta. Załóżmy, że komunikacja klienta i banku jest chroniona poświadczeniem autentyczności każdej wiadomości, dokonywanym przy użyciu metody wykorzystującej współdzielony sekret (jak omówiona wcześniej metoda MAC). Jeśli korespondencja nie jest szyfrowana, może być ona poznana przez osoby niepowołane, ale nikt nie jest w stanie ani modyfikować przesyłanych wiadomości, ani preparować nowych wiadomości, ponieważ nie zna klucza współdzielonego przez bank i klienta. Dlatego też, na pierwszy rzut oka wydawałoby się, że komunikacja banku i klienta jest bezpieczna i może być zastosowana w praktyce (można ją dodatkowo utajnić przy użyciu dowolnej metody szyfrowania, wspomnianej w poprzedniej części).

Załóżmy więc, że klient zleca bankowi wykonanie przelewu pewnej kwoty pieniędzy na konto innej osoby X, a bank wykonuje przelew. Następnie załóżmy, że klient wypiera się autorstwa dyspozycji, twierdząc, że dyspozycja została zlecona przez pracownika banku. Bank, będąc w posiadaniu współdzielonego klucza szyfrowania może, teoretycznie, preparować kryptogramy w imieniu klienta, co jest argumentem nie do odparcia podczas rozstrzygania ewentualnego sporu. Podsumowując przedstawiony przykład widać, że jeżeli komunikacja między dwoma stronami odbywa się przy użyciu szyfru bazującego na współdzielonym kluczu, to jedna ze stron zawsze może wyprzeć się autorstwa wiadomości. Oznacza to, że ochrona autentyczności wiadomości przy użyciu metod wykorzystujących klucze symetryczne, nie spełnia warunku tzw. **niezaprzeczalności**, niezbędnego dla możliwości jednoznacznej identyfikacji autora dokumentu elektronicznego.

Aby zapewnić niezaprzeczalność informacji uwierzytelniających wiadomości, konieczne jest opracowanie metody poświadczania autentyczności, bazującej na kluczach asymetrycznych. Podobnie jak przy szyfrowaniu asymetrycznym, do realizacji uwierzytelnienia stosowane byłyby dwa różne klucze. Pierwszy z nich byłby wykorzystywany do poświadczania autentyczności dokumentu („podpisywania" dokumentu), drugi zaś — do sprawdzania autentyczności dokumentu (sprawdzania „podpisu"). Gwarancję niezaprzeczalności tak sporządzanego poświadczenia stanowi fakt istnienia tylko jednego egzemplarza klucza, wykorzystywanego przez osobę podpisującą dokument.

5.1. Ochrona wiarygodności danych w kryptosystemie RSA

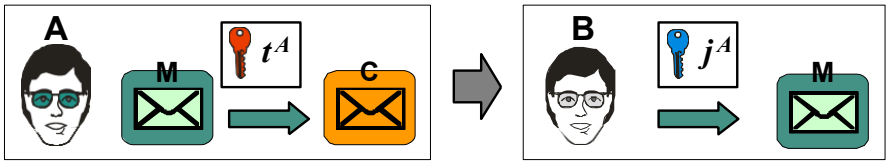
Sposobem na kryptograficzną ochronę danych, wykorzystującą asymetryczne klucze szyfrowania jest omówiona wcześniej metoda RSA. Okazuje się, że metoda RSA może zostać wykorzystana jako sposób poświadczania autentyczności dokumentów, wykorzystujący dwa różne klucze — pierwszy do podpisywania dokumentu i drugi do weryfikacji prawdziwości podpisu.

Aby zrozumieć istotę ochrony autentyczności danych w metodzie RSA, przypomnijmy sobie przedstawiony wcześniej przebieg procesu szyfrowania danych (rys. 5). Aby utajnić wiadomość przesyłaną do adresata, nadawca wiadomości szyfrował wiadomość kluczem publicznym adresata. Tylko posiadacz klucza prywatnego, pasującego do użytego klucza publicznego (a więc adresat wiadomości) jest w stanie odczytać kryptogram. Okazuje się, że procedura ochrony autentyczności wiadomości wymienianych między osobami A i B jest trywialną modyfikacją procedury szyfrowania i sprowadza się do prostej zmiany kolejności wykonywanych czynności (rys. 8):

1) osoba A sporządza wiadomość dla osoby B i szyfruje ją za pomocą swojego klucza prywatnego, po czym wysyła utworzony kryptogram do osoby B,
2) osoba B pobiera klucz publiczny osoby A i rozszyfrowuje przesyłkę.

Na pierwszy rzut oka wydaje się, że przedstawiona powyżej procedura to zwykłe szyfrowanie danych, a więc operacja, której celem jest ukrycie treści danych, a nie ochrona autentyczności danych. Zauważmy jednak, że każdy, kto wejdzie w posiadanie klucza publicznego osoby A jest w stanie dokonać deszyfracji przesyłki. Ponieważ klucz publiczny jest ze swojej definicji dostępny dla każdego, mimo że wiadomość pochodząca od A jest zaszyfrowana, jest ona wiadomością *de facto* jawną.

Cały sens przedstawionej procedury tkwi w tym, że klucz publiczny osoby A jest jedynym kluczem, który pozwoli na deszyfrację wiadomości. Nie istnieje żadna inna liczba, która pozwoliłaby na zmianę kryptogramu C w sensowną wiadomość M. Jeżeli zastosowanie klucza publicznego osoby A przekształca kryptogram C w wiadomość M, oznacza to, że C musiało być sporządzone kluczem prywatnym osoby A. Ponieważ zakładamy, że posiadacze kluczy prywatnych strzegą ich tajności, autorem rozszyfrowanej wiadomości musi być osoba A. Zauważmy, że realizacja przedstawionej procedury prowadzi do dwóch wniosków, kluczowych z punktu widzenia poświadczania autentyczności wiadomości. Po pierwsze, osoba A nie może wyprzeć się autorstwa wiadomości rozszyfrowanej za pomocą jej klucza publicznego, co daje jednoznaczną identyfikację pochodzenia wiadomości. Po drugie, wiadomość nie może zostać zmodyfikowana przez osobę trzecią, dane w zmienionej postaci musiałyby bowiem zostać ponownie zaszyfrowane, co wymaga użycia klucza prywatnego osoby A. W efekcie kryptosystem RSA pozwala na jednoczesną realizację ochrony integralności i poświadczenia autorstwa wiadomości.



Rysunek 8. Poświadczanie autentyczności wiadomości w kryptosystemie RSA

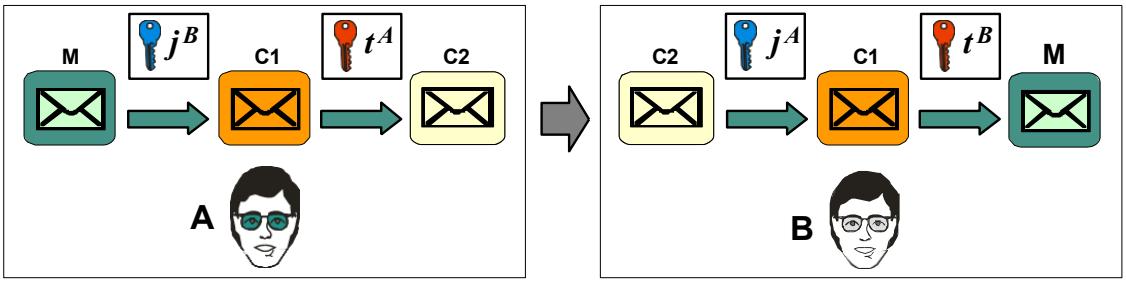
5.2. Jednoczesna ochrona wiarygodności i tajności wiadomości

Przedstawiony w poprzednim punkcie sposób ochrony wiarygodności danych może być połączony z opisanym wcześniej mechanizmem ochrony tajności danych i w efekcie, może pozwolić na realizację kompleksowej metody ochrony informacji. Możliwość zapewnienia pełnej ochrony danych stanowi największą zaletę kryptosystemu RSA. Realizacja wszystkich wymienionych form zabezpieczenia danych przeprowadzana jest w drodze wykonania procedury zawierającej następujące etapy (przedstawione schematycznie na rys. 9):

1 Osoba A tworzy wiadomość przeznaczoną dla osoby B, następnie szyfruje ją kluczem publicznym osoby B, tworząc kryptogram C1. Jak wcześniej wyjaśniono, tylko i wyłącznie B, jako posiadacz odpowiedniego klucza prywatnego, będzie w stanie odszyfrować tę wiadomość, czyli dokonać przekształcenia odwrotnego — C1 w M. W ten sposób zabezpieczona zostaje tajność wiadomości.

2 Osoba A dokonuje drugiego etapu przetwarzania danych — szyfruje uzyskany kryptogram C1 za pomocą swojego klucza tajnego, otrzymując kryptogram C2. Jak wcześniej wyjaśniono, wykonanie przekształcenia odwrotnego, a więc zamiana C2 w C1 będzie możliwe tylko i wyłącznie w wyniku deszyfracji C2 kluczem publicznym osoby A. W ten sposób zabezpieczona zostaje autentyczność i integralność wiadomości.

3 Osoba B otrzymuje od A kryptogram C2, pobiera klucz jawny osoby A i deszyfruje C2, otrzymując w efekcie C1. Następnie pobiera swój klucz tajny i dokonuje drugiej operacji deszyfracji, tym razem przekształcając C1 w oryginalną wiadomość M.



Rysunek 9. Kompleksowa ochrona danych w RSA: procedura gwarantuje jednocześnie tajność i wiarygodność danych

5.3. Podpisy cyfrowe

Uzyskanie pełnej ochrony zarówno tajności, jak i wiarygodności wiadomości jest możliwe w wyniku zastosowania algorytmu RSA. Teoretycznie można by więc uznać RSA za narzędzie rozwiązujące wszelkie problemy współczesnej kryptografii i zrezygnować ze stosowania wszelkich innych metod ochrony danych. Niestety, algorytm RSA jest bardzo złożony obliczeniowo, co sprawia, że zarówno dla ochrony tajności, jak i wiarygodności danych stosowane są obecnie procedury mieszane, korzystające z RSA (lub rozwiązań bazujących na podobnych ideach) w powiązaniu z innymi metodami ochrony. Przeanalizujmy praktyczne problemy związane ze stosowaniem RSA w celu zapewnienia integralności danych i identyfikacji ich autorstwa. Informację chroniącą autentyczność danych w RSA stanowi kryptogram, który jest wiadomością oryginalną, zaszyfrowaną kluczem prywatnym jej autora. Weryfikacja autentyczności autorstwa to deszyfracja kryptogramu kluczem publicznym autora. Zakładając, że klucz publiczny autora ma długość 128 bajtów, deszyfrowana wiadomość powinna być podzielona na bloki o mniej więcej takiej długości, które podlegają procedurze deszyfracji (odpowiada to mniej niż dwóm liniom standardowego tekstu). Przetwarzanie dłuższego tekstu wymaga wykonania

wielu operacji deszyfracji kolejnych linii kryptogramu (około czterdziestu na stronę tekstu). Oznacza to, że jeżeli deszyfracja jednego bloku zabierze jedną dziesiątą sekundy, to deszyfracja jednej strony zajmie cztery, a dziesięciu aż czterdzieści sekund. Ponieważ weryfikacja autentyczności danych przy użyciu RSA jest procedurą czasochłonną, podjęte zostały próby opracowania efektywniejszych metod realizacji tego zadania.

Przyjętą metodą ochrony wiarygodności danych stały się tzw. **podpisy cyfrowe**. Są one dokumentami elektronicznymi, dołączanymi do autoryzowanej wiadomości i zaświadczającymi o jej integralności i autorstwie. Ogólna idea ochrony jest więc podobna jak w przypadku ochrony integralności danych przy użyciu funkcji skrótu. W istocie, wyznaczanie skrótu wiadomości jest składnikiem wszystkich stosowanych obecnie procedur wyznaczania podpisu cyfrowego.

5.4. Wyznaczanie podpisu cyfrowego metodą RSA

Najprostszą pojęciowo metodą sporządzania podpisu cyfrowego jest połączenie omówionych wcześniej technik ochrony danych — funkcji skrótu i algorytmu RSA. Funkcja skrótu przekształca tekst o dowolnej długości w ciąg bajtów o niewielkim i stałym rozmiarze. Skrót wiadomości jest różny dla różnych wiadomości, dlatego też z punktu widzenia potwierdzenia integralności danych, podpisanie skrótu jest równoważne podpisaniu wiadomości. Podstawowym problemem, w odniesieniu do wykorzystania metody RSA do ochrony wiarygodności danych, było uzależnienie czasu weryfikacji od długości zabezpieczanej wiadomości. Jeżeli argumentem procedury zabezpieczania wiarygodności metodą RSA będzie skrót wiadomości zamiast oryginalnej wiadomości, rozwiążemy przedstawiony problem. Rozumowanie to przedstawia ideę postępowania stosowanego do wyznaczania podpisów cyfrowych metodą RSA.

Załóżmy, że osoba A chce wyznaczyć podpis cyfrowy dla sporządzonej przez siebie wiadomości M. Podpis cyfrowy ma być dokumentem dołączonym do wiadomości i ma gwarantować, że tekst tej wiadomości nie został przez nikogo zmodyfikowany oraz jednoznacznie zaświadczać o tym, kto jest jej autorem. Algorytm metody wyznaczania podpisu cyfrowego metodą RSA, przedstawiony schematycznie na rysunku 10, jest następujący:

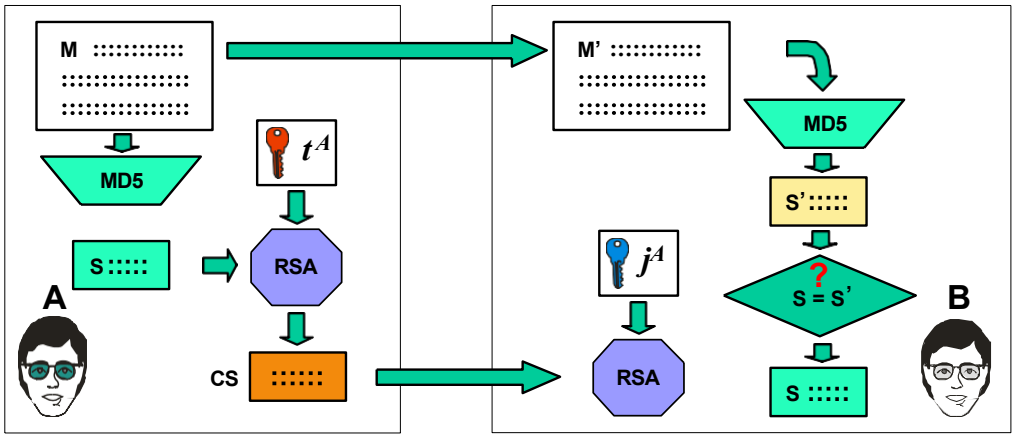
1. Osoba A wyznacza skrót S sporządzonej przez siebie wiadomości, przy użyciu wybranego przez siebie algorytmu (mimo, że nie istnieją teoretyczne ograniczenia co

do rodzaju używanego algorytmu, w praktyce, stosowana jest zwykle metoda MD-5 lub MD-4, tworząca 128-bitową reprezentację wiadomości).
2. Osoba A szyfruje skrót S swoim kluczem prywatnym, uzyskując w wyniku kryptogram CS.
3. Osoba A przesyła do odbiorcy (na przykład osoby B) wiadomość M i utworzony kryptogram CS.

Kryptogram CS stanowi podpis elektroniczny wiadomości M. Weryfikacja podpisu elektronicznego wiadomości M polega na wykonaniu następujących czynności (rys. 10):

1. Wyznaczeniu skrótu otrzymanej wiadomości M' — osoba B poddaje otrzymaną wiadomość M' operacji wyznaczenia skrótu, dokonywanej według tego samego algorytmu, który został użyty przez osobę A (ponieważ nie ma pewności, czy wiadomość otrzymana jest identyczna z nadaną, używany jest dla niej symbol M').
2. Deszyfracja otrzymanego przez osobę B kryptogramu CS — deszyfracja dokonywana przy użyciu klucza publicznego osoby A. Jej efektem jest uzyskanie skrótu oryginalnej wiadomości M, a więc S.
3. Porównanie skrótów wiadomości oryginalnej i otrzymanej oraz podjęcie decyzji, co do prawdziwości wiadomości M — identyczność porównywanych skrótów oznacza pomyślny wynik weryfikacji. Różnica między skrótami oznacza, że wiadomość została zmieniona lub skrót został utworzony przez inną osobę niż osoba A.

Pomyślna weryfikacja podpisu oznacza, że tekst otrzymanej wiadomości nie został przez nikogo zmodyfikowany i jednocześnie, że wiadomość została na pewno sporządzona przez osobę A.



Rysunek 10. Sporządzanie i weryfikacja podpisu cyfrowego wiadomości metodą RSA

5.5. Algorytm DSA wyznaczania podpisu cyfrowego

Algorytm DSA (skrót od angielskiego zwrotu *Digital Signature Algorithm*, czyli algorytm podpisu cyfrowego) jest najczęściej stosowanym obecnie sposobem wyznaczania podpisów cyfrowych. Ogólna istota przekształceń dokonywanych w algorytmie DSA jest podobna jak w omówionej wcześniej metodzie podpisywania przy użyciu RSA. Podpis dokumentu w metodzie DSA składa się z dwóch ciągów bitów o stałej długości, wynoszącej 160 bitów (20 bajtów), niezależnej od długości podpisanego dokumentu. Użytkownicy posiadają swoje klucze prywatne, służące do sporządzania podpisu oraz klucze publiczne, rozpowszechniane w celu jego weryfikacji.

Schemat blokowy algorytmu DSA jest analogiczny do przedstawionego na rysunku 10. Różnice dotyczą szczegółowych sposobów realizacji poszczególnych operacji. Argumentem operacji podpisywania jest w DSA wiadomość przekształcana do postaci skrótu, przy użyciu algorytmu SHA-1, a nie za pomocą algorytmu MD. Podobnie, przekształcenia matematyczne, którym poddawana jest przetwarzana wiadomość są nieco inne — wyznaczenie podpisu jest operacją zdefiniowaną w inny sposób niż ujmują to równania (1) i (2), również sprawdzenie podpisu jest dokonywane inaczej w przypadku metody RSA.

Bibliografia

1. Denning D. E., 1993: *Kryptografia i ochrona danych*, WNT, Warszawa.
2. Kippenhahn R., 2000: *Tajemne przekazy — szyfry, Enigma i karty chipowe*, Wydawnictwo Prószyński i S-ka, Warszawa.
3. Schneier B., 1995: *Kryptografia dla praktyków*, WNT, Warszawa.